

COMMONWEALTH OF AUSTRALIA

Copyright Regulations 1969

WARNING

This material has been copied and communicated to you by or on behalf of The University of Newcastle pursuant to Part VB of the Copyright Act 1968 (the Act).

The material in this communication may be subject to copyright under the Act. Any further copying or communication of this material by you may be the subject of copyright protection under the Act.

Do not remove this notice.

SENG1050

Web Technologies

Week 12 – Security, Privacy, and Ethics

Lecture Outline

- ☐ Security
- ☐ Privacy
- ☐ Ethics

Recall from last week: Encryption

- ❑ We have been using 'efficient and optimised' as shorthand for a website that is **scalable (week 7)**, **dynamic (week 8)**, **attractive to both humans and computers**, **responsive (week 9)**, **fast (weeks 9 & 10)**, and **secure (weeks 11 and 12)**.
- ❑ We have been looking at the issue of security – people will not want to visit a website that they cannot trust to keep their data secure. Last week we looked at how to secure data during transmission through the use of encryption.
- ❑ But there is a problem – encryption does not help if the server the data is stored on can be broken into.

Security

Malware

- ❑ Malware (**Malicious Software**) is an umbrella term for any type of “malicious software” that has been intentionally designed to cause damage to a computing device or network .
 - Software that causes unintentional harm is referred to as a ‘software bug’.
- ❑ There are many different types of malware depending on how they work and what they do.
- ❑ Sometimes malware and virus are used interchangeably.
 - But they are not the same. All viruses are malware, but not every malware is a virus.
- ❑ Common kinds of malware:
 - Virus
 - Ransomware
 - Spyware
 - Worms
 - Trojans
 - Botnets



Malware

- ❑ Virus: Computer program that can replicate itself and spread to other files after host file activation.
 - Most also deliver a “payload” of some sort (may be destructive or benign).
 - Include macro viruses, file-infecting viruses, and script viruses.
- ❑ Worms: Computer program that can replicate itself and spread from computer to computer without host file activation.
- ❑ Spyware: Collects information about a device or network, then relays this data back to the attacker.
- ❑ Trojan horse: Appears to be benign, but then does something other than expected. Usually setting up a backdoor/rootkit.
- ❑ Ransomware: Malware version of a ransom note. Works by locking or denying access to an entire system or some files until you pay the ransom.
- ❑ Botnet: can be covertly installed on a computer; responds to external commands sent by the attacker.

Malware

RANSOMWARE



Blackmails you

SPYWARE



Steals your data

ADWARE



Spams you with ads

Types of Malware

WORMS



Spread
across computers

TROJANS



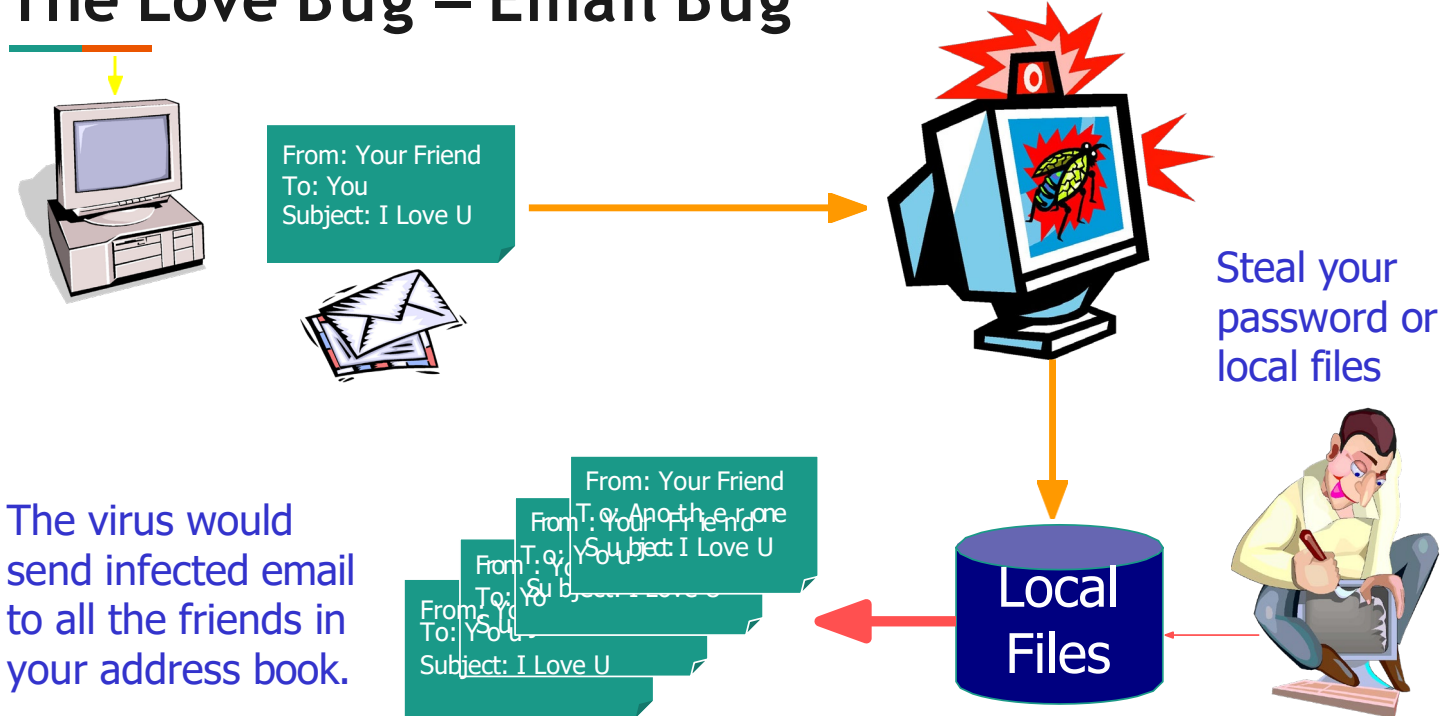
Sneak malware
onto your PC

BOTNETS



Turn your PC
into a zombie

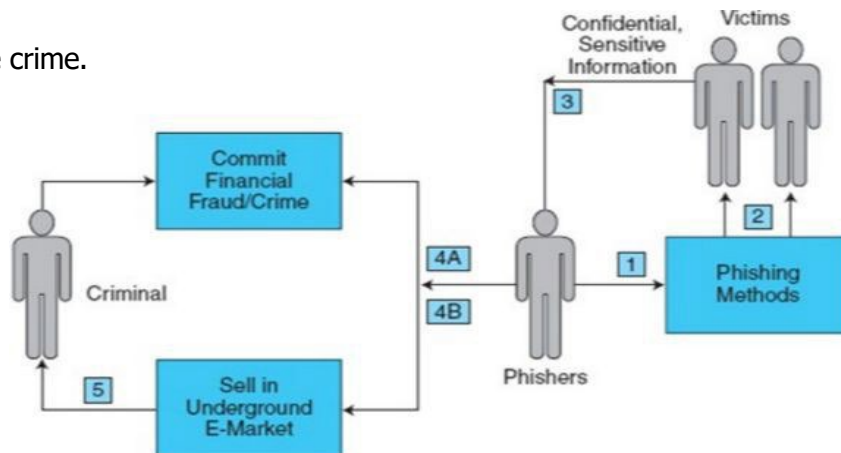
The Love Bug – Email Bug

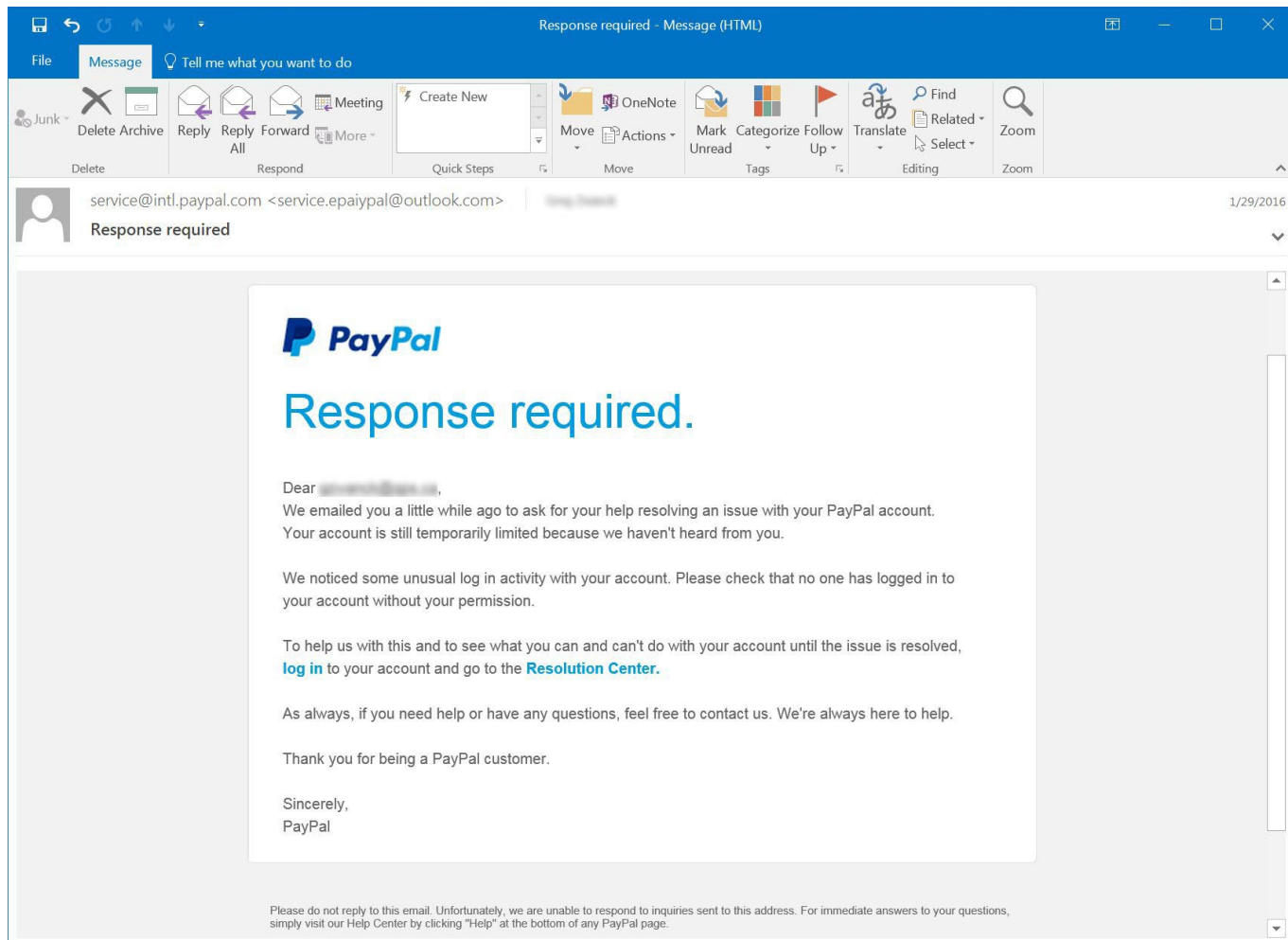




Phishing

- ❑ Any deceptive, online attempt by a third party to obtain confidential information for financial gain.
 - Most popular type: e-mail scam letters.
 - One of fastest growing forms of e-commerce crime.

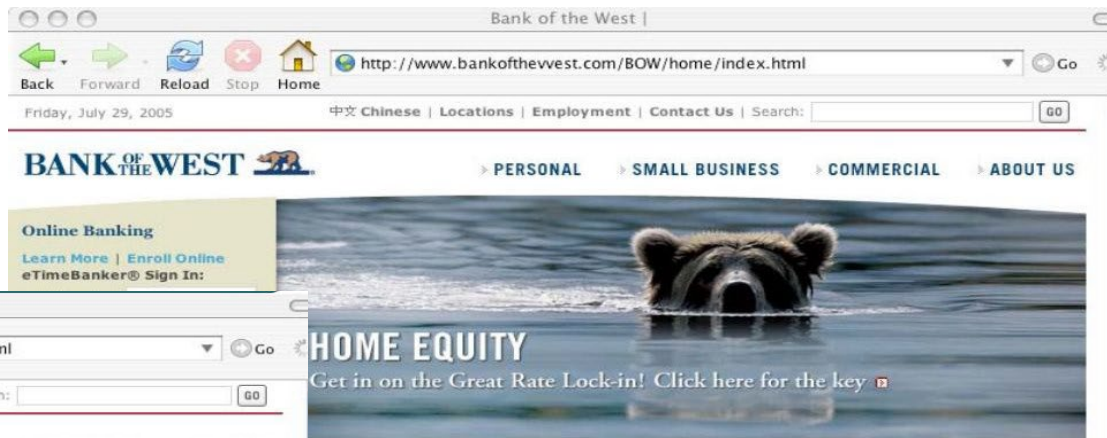
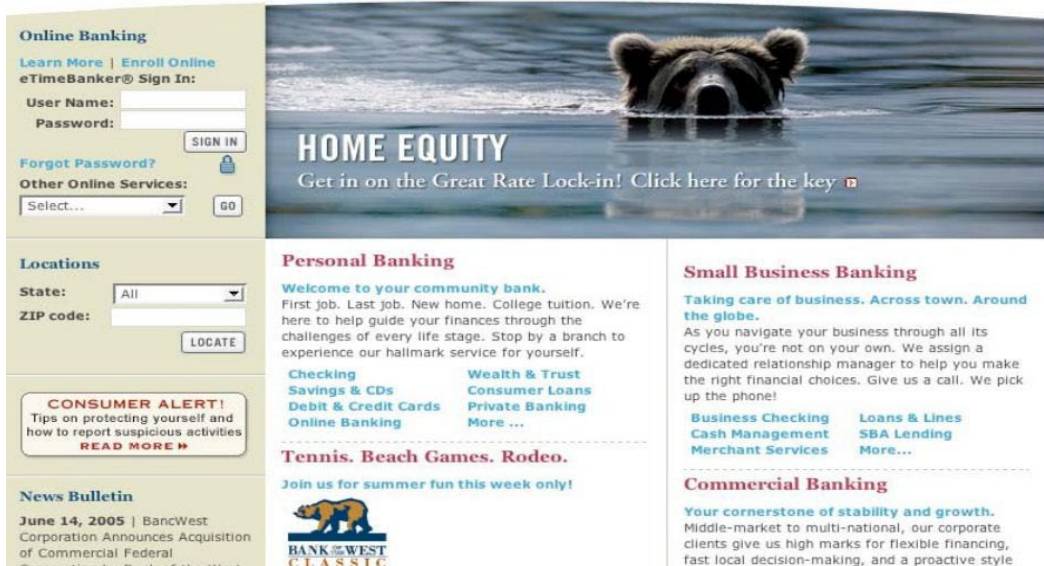






Spoofing (Pharming)

- ❑ Misrepresenting oneself by using fake e-mail addresses or masquerading as someone else.
- ❑ People typically enter a domain name (such as Google) while browsing online. Hackers access the domain name system server and change IP address, causing user to be redirected to spoofed (imitated) site.
- ❑ **Criminal intentions:**
 1. They want your money
 2. Steal business from other companies
 3. Alter your order and send it to the real site to process. They think it's funny to stick you with a thousand-dollar credit charge.



Source: Dhamija, Tygar & Hearst 2006



Identity Theft

- ❑ Fear that credit card information will be stolen deters online purchases.
- ❑ Hackers target credit card files and other customer information files on merchant servers; use stolen data to establish credit under false identity.
- ❑ One solution: New identity verification mechanisms.





Hacking and Cybervandalism

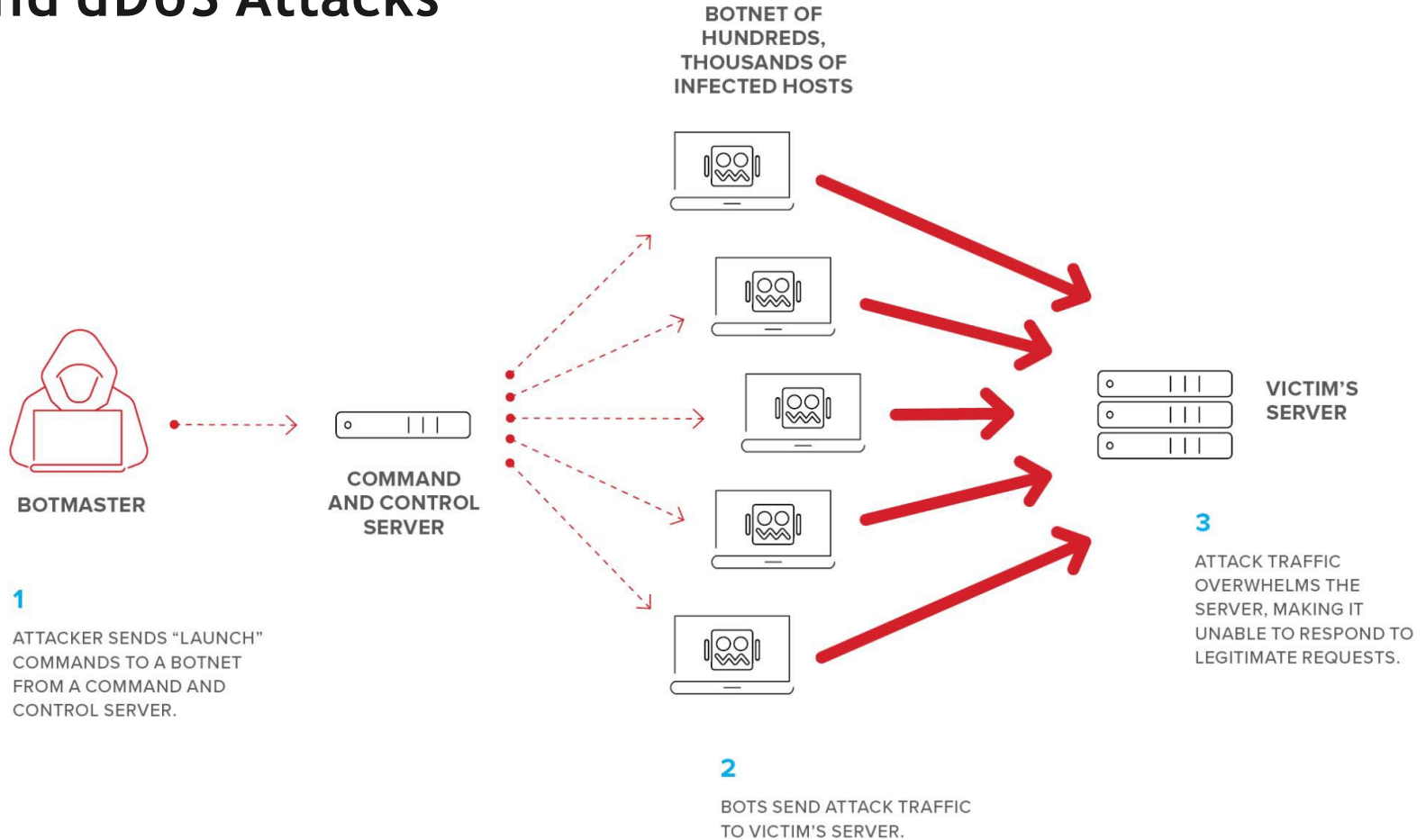
- ❑ Hacker: Individual who intends to gain access to computer systems using non-standard terms.
- ❑ Cracker: Used to denote hacker with criminal intent (two terms often used interchangeably).
- ❑ Cybervandalism: Intentionally disrupting, defacing or destroying a Web site.
 - E.g., North Korea and the Sony Pictures hack (2014).
- ❑ Types of hackers include:
 - White hats.
 - Black hats.
 - Grey hats.



DoS and dDoS Attacks

- ❑ Denial of service (DoS) attack: perpetrators flood Website with useless traffic to inundate and overwhelm network.
 - E.g., If a mail server is capable of receiving and delivering 10 messages a second, an attacker simply sends 20 messages per second.
- ❑ Distributed denial of service (dDoS) attack: hackers use numerous computers to attack target network from numerous launch points.
- ❑ Windows' PING command:
 - `C:\>ping -n 2 -l 1450 131.107.8.1.`
 - The most famous attack is "IP Ping of Death" in 1997.

DoS and dDoS Attacks





DoS and dDoS Attacks

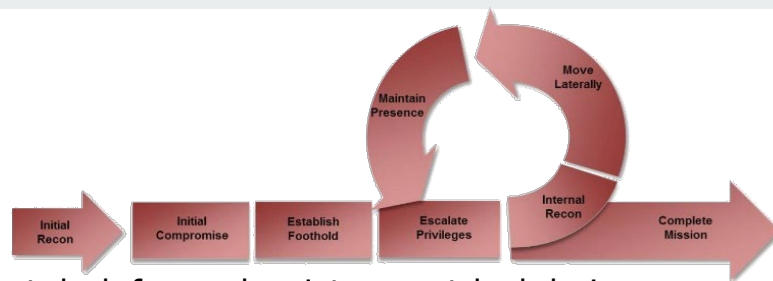
- ❑ **Consequences:**

- ❑ Causes company website to overload and prevents users from accessing it.
 - ❑ Destroys company's business and reputation.

- ❑ **Intent:** Competition, cyberwarfare,, hacktivism, revenge.



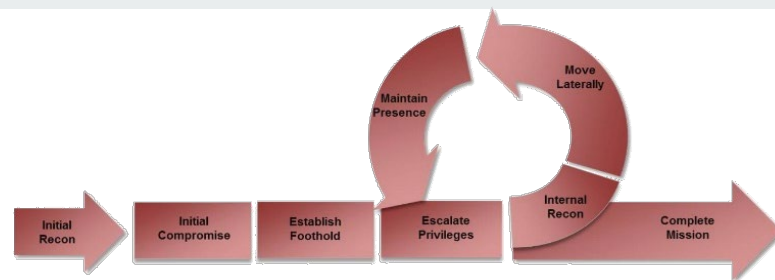
Cyber Attack Cycle



- ❑ Initial Reconnaissance: Conduct research on the target, look for weak points, unpatched devices, brands and versions of server software, anti-virus products, operating systems, etc.
- ❑ Initial Compromise: Malicious code is executed on a target device. Two main types of exploits, social engineering (trick a human into running malicious code – fake emails, spear phishing, fake phone calls), and zero-click malware (no human interaction required, exploits on unpatched systems, zero-day exploits).
- ❑ Establish Foothold: Ensure that the device remains under the attacker's control. Install persistent backdoors, download additional tools to target system.
- ❑ Escalate Privileges: Attempt to gain administrative access. Crack passwords with weak encryption, keylogger to collect password from human input, additional software exploits.
- ❑ Internal Reconnaissance: Scan the network, find additional devices, locations of databases, identify key servers, find the usernames of administrative accounts.



Cyber Attack Cycle



- ❑ Move Laterally: Use existing access to compromise more devices on the same network. Access shared folders, remote execution tools, task scheduling, etc.
- ❑ Maintain Presence: Ensure the compromised environment can continue to be accessed. Install rootkits, additional backdoors, steal VPN credentials.
- ❑ Complete Mission: Execute malware payload – encrypt files for ransom, steal banking/corporate data, steal private user data submitted to web server, etc.
- ❑ Remove Traces: Once the mission is complete, quietly remove all evidence of network compromise, delete log files, change timestamps.



Disrupting the Cyber Attack Cycle

- ❑ Initial Reconnaissance: Hide information (do not rely solely on security by obscurity, but it can be helpful in combination with other forms of protection), remove server signatures, disable device responding to ping requests, educate employees (e.g. not to give out sensitive information over the phone).
- ❑ Initial Compromise: For social engineering attacks – Email scanning/filtering software, security education, for zero-click attacks – keep software up-to-date, firewalls, next-gen anti-malware with behavioural analytics (vendors are currently experimenting with AI detection tools) can spot some zero-day exploits, device hardening – remove software and OS features that are not essential, which reduces the attack surface.
- ❑ Establish Foothold: Security software such as Anti-virus, anti-malware, endpoint protection, detection and response software are all used here to detect, monitor, isolate, and remove malicious code.



Disrupting the Cyber Attack Cycle

- ❑ Escalate Privileges: Use multi-factor authentication (so stealing a password is not enough), account lockout (lock account after a certain number of failed login attempts – helps to prevent brute-force password attacks) distributed administration (different accounts to perform different administrative tasks, no single account has unlimited privileges), block shared passwords across multiple accounts (check for duplicate password hashes and prompt user to change password if a duplicate is found). Principle of least privilege (each user account should have only the privileges required for the account to perform its function, and no more).
- ❑ Internal Reconnaissance: Use internal firewalls, block common scanning protocols that aren't legitimately needed, place sensitive devices on a separate subnet.



Disrupting the Cyber Attack Cycle

- ❑ Move Laterally: Implement network segmentation, role-based access, disable unneeded communication protocols such as SMB, log access to critical resources.
- ❑ Maintain Presence: Anti-rootkit software, monitor changes to start-up applications and scheduled tasks, restrict privileged access from VPN (e.g. block administrative credentials from being used remotely through a VPN, they must originate from a local, secured device).
- ❑ Complete Mission: Maintain offline backups to restore encrypted or corrupted files without paying a ransom, implement a whitelist policy for outbound connections on critical devices.
- ❑ Remove Traces: Automatically backup log files with a separate set of credentials, take regular snapshots of virtual devices.

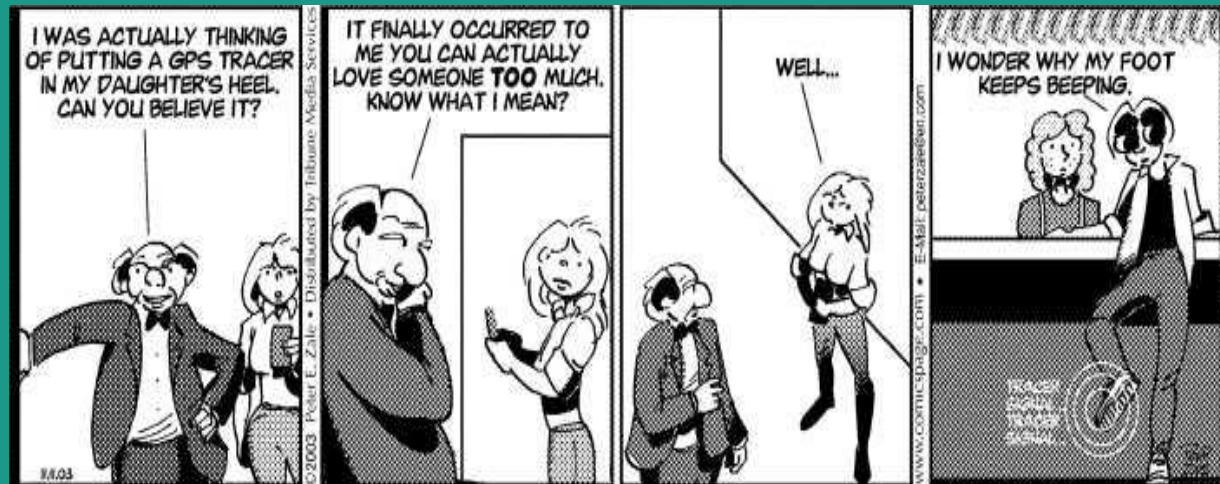


Technology Solutions

- ❑ Protecting your computer.
 - Updating OS regularly.
 - Antivirus software: real time protection.
- ❑ Protecting Internet communications (encryption)
- ❑ Securing channels of communication (SSL, S-HTTP, VPNs)
- ❑ Protecting networks (firewalls)
- ❑ Protecting servers and clients
- ❑ Use multiple layers of protection (no single layer is foolproof!)



Privacy





The Concept of Privacy

- ❑ Information privacy: Includes both the claim that certain information should not be collected at all, as well as the claim of individuals to control the use of whatever information is collected about them.



Computers and Privacy

- ❑ Web sites can collect information
 - IP address of machine, machines O/S, type of browser used, session identifier, requested pages, time of request and links followed.
- ❑ Cookies
 - When you visit a site, site creates cookie and stores it on your machine. Next visit, cookie is retrieved, updated and restored.
 - Useful for shopping over several visits, or not having to re-register on each visit.
 - They are not executable code.



Information Collected at Web Sites

- ❑ Personally identifiable information (PII): Data that can be used to identify, locate, or contact an individual (e.g., email address, name, driver's licence number, currently logged in social media account).
- ❑ Anonymous information: Demographic and behavioral information that does not include any personal identifiers (e.g., pages visited on a website, and time spent on each one).
- ❑ Almost all e-commerce companies collect PII and use cookies to track clickstream behavior.



Profiling and Behavioral Targeting

- ❑ Profiling: Creation of digital images that characterize online individual and group behavior.
- ❑ Anonymous profiles: Identify people as belonging to highly specific and targeted groups.
- ❑ Personal profiles: Add personal identifiers.
- ❑ Advertising networks can:
 - Track both consumer behavior and browsing behavior on the web.
 - Dynamically adjust what the user sees on screen.
 - Build and refresh high-resolution data images or behavior profiles of consumers.



Informed Consent

- ❑ Consent given with knowledge of all the material facts needed to make a rational decision.
- ❑ Two models:
 - Opt-in: Agreement that requires computer users to take specific steps to *allow* the collection of personal information.
 - Opt-out: Agreement that requires computer users to take specific steps to *prevent* the collection of personal information.



Solutions to Privacy Invasion on the Web

- ❑ Many privacy-enhancing technologies being developed emphasize security.
- ❑ These include:
 - Private browsing
 - Anonymous remailer
 - Anonymous proxy



Privacy Law in Australia

- ❑ The Privacy Act 1988 (last amended in 2015) sets out the 13 key principles for the collection of personal information (PII) by any APP entity (an agency or organisation):
 - **Australian Privacy Principle 1 — open and transparent management of personal information:**
This sets out the need for a freely accessible, up-to-date privacy policy that states the kinds of personal information collected, how and why the information is collected and stored, and how an individual can access their stored personal information.
 - **Australian Privacy Principle 2 — anonymity and pseudonymity:**
Individuals must have the option of using a pseudonym, or simply not identifying themselves, unless it would not be practical for the entity to deal with individuals who have not identified themselves.



Privacy Law in Australia

➤ **Australian Privacy Principle 3 — collection of solicited personal information:**

Personal information cannot be collected unless this information is reasonably necessary for the entity to perform one or more of its functions or activities. Sensitive information in particular cannot be collected without explicit consent. Sensitive information is personal information that is also considered to be especially private (e.g. political opinions, racial origin, sexual orientation, religious beliefs, criminal record, health information, etc).

➤ **Australian Privacy Principle 4 — dealing with unsolicited personal information:**

If personal information is collected without the knowledge or consent of the user, the entity must destroy or de-identify the information if it could not have been reasonably collected under principle 3 above.

➤ **Australian Privacy Principle 5 — notification of the collection of personal information:**

When personal information is collected, the entity must notify the user or otherwise ensure the user is made aware as soon as possible that the information has been collected, how and why the information was collected, and where the entities' privacy policy can be found.



Privacy Law in Australia

- **Australian Privacy Principle 6 — use or disclosure of personal information:**

Personal information collected for a particular purpose, may not be used or disclosed to another entity for an additional or different purpose without the consent of the user.

- **Australian Privacy Principle 7 — direct marketing:**

Personal information may not be used or disclosed for direct marketing purposes unless: The individual is aware that this may occur **AND** an opt-out mechanism is provided. The opt-out mechanism must be included in all direct marketing communications.

- **Australian Privacy Principle 8 — cross-border disclosure of personal information:**

Personal information may not be disclosed to an entity outside Australia without the knowledge and consent of the individual. The entity outside Australia must be subject to a privacy law of a similar nature to the Privacy Act.



Privacy Law in Australia

- **Australian Privacy Principle 9 — adoption, use or disclosure of government related identifiers:**
A government related identifier is an identifier issued by a government entity to identify an individual.
An APP entity must not adopt any government related identifier of an individual as its own identifier for that individual. An APP entity must not use or disclose any government related identifier of an individual unless required by law, or for the explicit purpose of verifying the individual's identity.
- **Australian Privacy Principle 10 — quality of personal information:**
Personal information collected should be kept accurate, complete, and up-to-date as much as reasonably possible in relation to the purpose for which the information was collected.
- **Australian Privacy Principle 11 — security of personal information:**
Personal information must be protected as much as reasonably possible from misuse, interference, loss, unauthorised access, unauthorised modification, and unauthorised disclosure. Personal information that is no longer required for a valid purpose must be destroyed or de-identified as soon as is practical.



Privacy Law in Australia

➤ **Australian Privacy Principle 12 — access to personal information:**

Personal information held about an individual must be made freely available to that individual on request as soon as reasonably possible UNLESS this would pose a threat to the health, life, or safety of an individual or the public, or if this would impact the privacy of other individuals.

➤ **Australian Privacy Principle 13 — correction of personal information:**

Personal information held about an individual must be corrected on request by the individual if the individual demonstrates that the stored information is out-of-date, incomplete, inaccurate, or misleading for the purpose for which it was collected.

N.B. The above is a simplified, summarised version of the legislation for educational purposes, and omits various details, exceptions, and subclauses.

This should not be construed as legal advice, view the full text at <https://www.legislation.gov.au/Details/C2014C00076>
Privacy Act 1988 (Cth) sch 1 ('Australian Privacy Principles')

Ethics

Ethics

- ❑ A branch of philosophy dealing with what is considered to be right or wrong.
- ❑ Unethical $\neq$ illegal

Illegal	Ethical but Illegal	Unethical And Illegal
	Legal And Ethical	Legal But Unethical
Legal		
	Ethical	Unethical

Lying to your boss to get a day off for watching a game of Test Cricket.

Finding \$50 000 dropped on the ground, picking it up and keeping it for yourself.

Running a red light while driving a friend to the hospital in an emergency.

Copying an essay from the internet and passing it off as your own work.

Ethics

- ❑ What is considered unethical can depend upon:
 - Organization
 - Country
 - Culture
 - Value systems
 - Circumstances at the time

Can humans be ethical in one environment and unethical in another environment?



5 Basic Ethical Concepts

1. Ethics
2. Responsibility
3. Accountability
4. Liability
5. Due process



5 Basic Ethical Concepts

1. Ethics

- Principles of right & wrong used by free groups and organizations to make choices in their behavior.
- Morals vs Ethics vs Law: Morals and Ethics in particular, are often used interchangeably, and different definitions are used by various sources. For simplicity, the dictionary definitions will be used here:
Morals refers to standards for right and wrong character and behaviour – typically used in practice to refer to values and choices at an individual level.
Ethics refers to the study of what is morally right and wrong, or a set of beliefs about what is morally right and wrong – typically used in practice to refer to values and choices at a collective level (groups, organisations, professions), e.g. code of conduct, professional ethics.
Law refers to a system of rules, usually made by a government, used to order the way in which a society behaves – typically used at a societal or national level.



5 Basic Ethical Concepts

2. Responsibility

- As free moral agents, individuals, organizations, and societies are responsible for the actions they take.
- Accepting, voluntarily or non-voluntarily, potential costs, duties, and obligations for their decisions.
- The principle of absolute responsibility states that responsibility cannot be delegated, only authority can be delegated. If a job delegated by a manager to subordinates is not completed, the manager will still usually be held responsible by the executives who gave the manager the job in the first place, thus the manager must always maintain some amount of oversight.
- **The Internet: Power Without Responsibility?**
 - *Spider-Man* (2002): "With great power comes great responsibility." - If Internet users abandon moral rules – if it becomes a moral wilderness -- that will destroy the trust required for its operation. It will become useless.



5 Basic Ethical Concepts

3. Accountability

- Mechanisms for identifying responsible parties.
 - Ways of assessing responsibility for decisions made and actions taken.
 - Determining who should take responsibility for decisions and actions.
 - Who will be held accountable if harm is done?
 - Who is to be held responsible for faulty computers? Software?
 - Methods of ensuring accountability may include audit logs, written contracts, public hearings, etc.





5 Basic Ethical Concepts

4. Liability

- A feature of political systems in which a body of law is in place that permits individuals to recover the damages done to them by other actors, systems, or organizations.
- Legally placing responsibility with a person or organizations.
- Permits individuals and organizations to recover damages done to them by others.



5 Basic Ethical Concepts

5. Due process

- Is fair procedures for making decisions.
 - An individual is treated fairly and uniformly at all times with basic rights protected.
- Is a related feature of law-governed societies.
- is a process in which laws are known and understood.
- there is an ability to appeal to higher authorities to ensure that the laws are applied correctly.
- not only provides guidance for good conduct but also administratively and legally punishes misconduct.
- Process must be fair & follow established procedures.

Ethics - Computer and Internet

- ❑ Walter Maner in the 1970s decided to use the term “computer ethics”
- ❑ Computer Ethics are a set of moral principles that govern an individual or a group on [what is acceptable behaviour](#) while using a computer.
- ❑ Aside from respecting privacy, one of the common issues of computer ethics is violation of copyright issues.
 - ❑ Early copyright was modelled after the Statute of Anne in 1710 – the basic idea was to incentivise learning, creation, and invention by giving the creator an exclusive right to profit from their work for a set period of time. *“One person studies seven years, to bring a finished piece into the world, and a pirate printer, reprints their copy immediately, and sells it for a quarter of the price ... these things call for an Act of Parliament” – (Daniel Defoe, 1705)*
- ❑ Internet ethics means [acceptable behaviour](#) for using the Internet.
- ❑ We should be honest, respect the rights and property of others on the Internet.



Ethical rules for computer users

- ❑ Do not use computers to harm other users.
- ❑ Do not use computers to steal others information.
- ❑ Do not access files without the permission of the owner.
 - *Crimes Act 1900* (NSW) s 308H [Max 2 years imprisonment]
- ❑ Do not copy copyrighted software without the author's permission.
 - *Copyright Act 1968* (Cth) s 132AI [Max 5 years imprisonment] (Seeding)
- ❑ Always respect copyright laws and policies.
- ❑ Respect the privacy of others, just as you expect the same from others.
- ❑ Do not use other user's computer resources without their permission.
- ❑ Do not disrupt or impair communication to or from a computer without the owner's permission.
 - *Crimes Act 1900* (NSW) s 308E [Max 10 years imprisonment]
- ❑ Use the Internet ethically.
- ❑ Complain about illegal communication and activities, if found, to Internet service Providers and local law enforcement authorities.
- ❑ Users are responsible for safeguarding their User Id and Passwords. They should not write them on paper or anywhere else for remembrance.
- ❑ Users should not intentionally use the computers to retrieve or modify the information of others, which may include password information, files, etc..



Summary

- ❑ We have looked at issues surrounding data at the endpoint devices, the need to keep it secure, some of the common threats and attacks that target data.
- ❑ We have looked at the data itself – what user data we collect, the need for privacy, and some of the legal requirements for this.
- ❑ Finally, we have looked at some of the general ethical issues and principles that govern the use of the computers generally, and the internet in particular.
- ❑ We have finally completed our goal – we have covered everything we need to create an efficient, optimised website on the internet, accessible using the world wide web!

References

- ❑ <https://www.avast.com/c-malware>
- ❑ <https://www.f5.com/labs/articles/education/what-is-a-distributed-denial-of-service-attack->
- ❑ E-commerce (2012) eight edition, Kenneth C. Laudon, Carol Guercio Traver
- ❑ Data Communications and Networking (5e)
 - *By Behrouz A. Forouzan*
 - *Chapters 31.1 and 32.4*
- ❑ <https://www.iacpcybercenter.org/resource-center/what-is-cyber-crime/cyber-attack-lifecycle/>
- ❑ <https://www.legislation.gov.au/Details/C2014C00076>
- ❑ <https://legislation.nsw.gov.au/view/html/inforce/current/act-1900-040>